MunichTech GmbH

INFORMATION SECURITY MANAGEMENT SYSTEM

Risk Assessment Methodology

Document Reference	MT-ISMS-RAM-001
Version	1.2
Effective Date	26 October 2026
Prepared By	Austin Bond, Junior GRC Consultant
Reviewed By	Dr. Andreas Kellermann, CISM, ISO LA
Approved By	CEO / Managing Director, MunichTech GmbH
Confidentiality Level	**CONFIDENTIAL** — Internal Use Only

Version	*Date*	*Author*	*Change Description*
1.0	4 November 2025	Austin Bond	Initial methodology creation; aligned with ISO 27001:2022 Clause 6.1.2 and NIS2 reporting thresholds
1.1	14 January 2026	Austin Bond	Currency update: NIS-2 review trigger restated against the German NIS-2-Umsetzungsgesetz and revised BSIG; reporting threshold now cites Sec. 32 BSIG.
1.2	26 October 2026	Austin Bond	Consistency pass: Risk acceptance criteria now state explicitly that acceptance is judged on the residual score, with a CEO countersignature required where the inherent score is 12 or higher. Vulnerability Severity table corrected: the missing Low row is restored and the duplicated Medium definition removed. No scoring factor or threshold changed.

Table of Contents

1. Purpose and Scope
2. Assessment Frequency and Triggers
3. Risk Calculation Methodology
4. Factor Definitions and Scoring
5. Risk Classification Matrix
6. Risk Acceptance Criteria
7. Risk Treatment Process
8. Document Sign-Off

1. Purpose and Scope

This document defines the methodology utilized by MunichTech GmbH to identify, analyze, and evaluate information security risks. It has been developed to satisfy the requirements of ISO/IEC 27001:2022 Clause 6.1.2 (Information security risk assessment) and provides the framework for all entries in the MunichTech GmbH Risk Register (MT-ISMS-RR-001).

The purpose of this methodology is to ensure that risk assessments produce consistent, valid, and comparable results, allowing executive leadership to prioritize security investments and technical remediation efforts based on actual business exposure, regulatory liability (DSGVO, NIS2), and contractual SLA commitments.

2. Assessment Frequency and Triggers

Risk assessments are not static. The Information Security team (led by the Head of Engineering (Interim CISO)) shall conduct risk assessments under the following conditions:

- Annually: A comprehensive review of the entire Risk Register prior to the Management Review.
- Major Architectural Change: Prior to deploying new core infrastructure, adopting new cloud environments, or significantly altering the SaaS analytics engine.
- Post-Incident: Immediately following any confirmed security breach, severe near-miss, or SLA-violating outage.
- Regulatory Shift: Following major changes in German/EU law (e.g., the German NIS-2-Umsetzungsgesetz and the revised BSIG).

3. Risk Calculation Methodology

MunichTech GmbH utilizes a qualitative, three-factor risk calculation model. The Inherent Risk (the risk level before any mitigating controls are applied) and the Residual Risk (the risk remaining after controls are applied) are calculated using the following formula:

$$Risk\ Score\ =\ Asset\ Value\ (Impact) \times Threat\ Likelihood\ \times Vulnerability\ Severity$$

Each factor is scored on a scale of 1 to 3.

The minimum possible score is 1 (1 × 1 × 1). The maximum possible score is 27 (3 × 3 × 3).

4. Factor Definitions and Scoring

4.1 Asset Value (Business Impact)

Derived directly from the Confidentiality, Integrity, and Availability (CIA) scores documented in the Information Asset Register (MT-ISMS-IAR-001). The highest CIA value of the targeted asset is used as the base Asset Value score.

Score	*Level*	*Definition & Business Context*
3	High	Critical impact on business operations. Data breach involving client financial data or PII triggering mandatory 72-hour DSGVO/BayLDA notification. SaaS platform outage exceeding contractual SLAs and triggering § 32 BSIG (NIS2 Art. 23) reporting thresholds. Severe reputational damage and client churn.
2	Medium	Moderate impact. Degradation of internal systems affecting engineering productivity but not directly impacting client-facing SaaS delivery. Minor data exposure not requiring regulatory notification. Recoverable within standard RTO without severe financial penalty.
1	Low	Negligible impact. Publicly available data, or isolated disruption to non-critical internal tools (e.g., meeting room booking systems) with readily available manual workarounds. No regulatory impact.

4.2 Threat Likelihood

The probability of a threat actor or natural event attempting to exploit the asset. Informed by industry threat intelligence (e.g., ENISA Threat Landscape).

Score	*Level*	*Definition & Business Context*
3	High	Highly motivated and capable threat actors (e.g., ransomware gangs targeting financial sector supply chains, malicious insiders). The threat event occurs frequently in the industry or is actively occurring against MunichTech GmbH infrastructure (e.g., continuous automated credential stuffing).
2	Medium	Opportunistic or automated threats without specific targeting of MunichTech GmbH (e.g., untargeted phishing campaigns, automated vulnerability scanners). Expected to occur at least once a year.
1	Low	Rare or purely theoretical threats. Highly complex attack vectors requiring physical access to the Munich AWS data centers, or rare natural disasters (e.g., severe earthquakes in Bavaria).

4.3 Vulnerability Severity

The ease with which a threat can exploit a weakness in the system, processes, or personnel.

Score	*Level*	*Definition & Business Context*
3	High	Trivial to exploit. Unauthenticated Remote Code Execution (RCE), exposed S3 buckets, lack of MFA on external interfaces, or known critical CVEs with active exploits available in the wild.
2	Medium	Requires some effort to exploit. Requires authenticated access, user

		interaction (e.g., clicking a phishing link), or chaining multiple medium-severity vulnerabilities together.
1	Low	Difficult to exploit. Requires significant preconditions such as privileged credentials, physical presence or a highly specific configuration, and no known exploit exists in the wild.

5. Risk Classification Matrix

By multiplying the three factors (1–3 scale), the resulting Risk Score dictates the overall Risk Classification and urgency of response.

Risk Score	*Classification*	*Action Required & SLA*
27	CRITICAL	Unacceptable risk. Immediate cessation of the affected business process or system until mitigated. Requires emergency CEO/Board notification. Remediation SLA: 24 Hours.
12 – 18	HIGH	Significant exposure. Immediate mitigation project must be prioritized over feature development. Requires Head of Engineering (Interim CISO) approval. Remediation SLA: 14 Days.
6 – 9	MODERATE	Standard operational risk. Mitigate during normal operational cycles or accept with documented business justification. Remediation SLA: 90 Days.
1 – 4	LOW	Acceptable risk. Monitored via standard operational procedures. No immediate action required.

6. Risk Acceptance Criteria

In alignment with ISO 27001:2022 Clause 6.1.2(a) and the MunichTech GmbH Risk Appetite Statement (MT-ISMS-SCO-001 Section 7), acceptance is judged on the residual score, and a further CEO countersignature is required where the inherent score is High or Critical. The following criteria apply:

- Low and Moderate residual risks (Scores 1–9): May be accepted by the respective Asset Owner (e.g., VP of Product, HR Manager) without further executive escalation, provided the acceptance is formally documented in the Risk Register.
- High residual risks (Scores 12–18): Fall outside the standard risk appetite. May only be accepted with a formally documented business justification signed by the CEO /

Managing Director. The same CEO countersignature is required for any risk whose inherent score is 12 or higher, regardless of its residual score.

- Critical residual risks (Score 27): Zero tolerance. May not be accepted under any circumstances. Must be mitigated, transferred, or the associated business activity must be avoided.

7. Risk Treatment Process

For all risks identified, MunichTech GmbH will select one of the following treatment options in accordance with **ISO 27001:2022 Clause 6.1.3:**

1. Mitigate (Modify): Apply appropriate security controls from ISO 27001:2022 Annex A to reduce the Threat Likelihood or Vulnerability Severity (e.g., implementing MFA Annex A 5.17 to mitigate credential theft).
2. Transfer (Share): Shift the financial or operational impact of the risk to a third party (e.g., purchasing Cyber Liability Insurance, or utilizing AWS for physical security).
3. Avoid: Halt the activity causing the risk (e.g., choosing not to ingest a highly toxic financial dataset because the compliance cost outweighs the revenue).
4. Accept (Retain): Acknowledge the risk and proceed without further mitigation, subject to the Risk Acceptance Criteria in Section 6.

All selected treatments, alongside their corresponding Annex A control references and assigned owners, are documented in the Risk Register (MT-ISMS-RR-001).

DOCUMENT APPROVAL

PREPARED BY	
Name	Austin Bond
Title	Junior GRC Consultant
Date	13 January 2026
Signature	
REVIEWED BY	
Name	Dr. Andreas Kellermann
Title	Senior GRC Partner, CISM | ISO 27001 Lead Auditor
Date	13 January 2026
Signature	
APPROVED BY	
Name	Dr. Katharina Vogt
Title	Chief Executive Officer, MunichTech GmbH
Date	14 January 2026
Signature	